MICHEL Erwan

De: erwan.michel@oxilum.fr
Envoyé: vendredi 20 février 2026 11:14
À: MICHEL Erwan
Objet: RE: Test

Métriques de l'audit
Types de constats de conformité
L'évaluation des constats repose sur l'échelle de valorisation proposée ci-dessous :

Conclusion	Description
Conforme	L'exigence est satisfaite [ISO 19011-2018 : 3.20]. Les preuves apportées permettent de conclure à la conformité du critère.
Remarque	Dysfonctionnement potentiel non décelé par l'audit ou qui ne fait pas l'objet d'une exigence dans les critères d'audit, et qui fait courir un risque limité sur le système. Inadéquation entre la situation constatée et le critère d'audit qui n'affecte pas directement le système. Défaillance constatée certainement due à un oubli ponctuel et n'est pas systématique.
Non-conformité mineure	L'exigence n'est pas satisfaite [ISO 19011-2018 : 3.21]. Les preuves apportées par l'audité ne permettent pas de conclure à la conformité au critère. Cette défaillance entraîne un niveau de risque important au maximum.
Non-conformité Majeure	L'exigence n'est pas satisfaite [ISO 19011-2018 : 3.21]. Les preuves apportées par l'audité ne permettent pas de conclure à la conformité au critère. Cette défaillance entraîne un niveau de risque au moins majeur.
Non Applicable	L'exigence n'est pas applicable ou n'a pas été auditée

Métriques de calcul du niveau de risque
Usage dans le cas général
A chaque non-conformité est associée une estimation du risque encouru. L'évaluation des risques repose sur les échelles de valorisation proposée à l'annexe C du RGS (référentiel PASSI) et est rappelée ci-dessous :

Facilité d'exploitation	
Facile	Exploitation triviale, sans outil particulier
Modérée	Exploitation nécessitant des techniques simples et des outils disponibles publiquement
Elevée	Exploitation de vulnérabilités publiques nécessitant des compétences en sécurité des systèmes d'information et le développement d'outils simples
Difficile	Exploitation de vulnérabilités non publiées nécessitant une expertise en sécurité des systèmes d'information et le développement d'outils spécifiques et ciblés

Impact	
Critique	Conséquences généralisées sur l'ensemble du système d'information audité
Majeur	Conséquences restreintes sur une partie du système d'information audité
Important	Conséquences isolées sur des points précis du système d'information audité
Mineur	Pas de conséquence directe sur la sécurité du système d'information audité

Matrice de calcul du niveau de risque				
Impact/Facilité d'exploitation	Difficile	Elevée	Modérée	Facile
Mineur	Mineur	Mineur	Important	Majeur
Important	Mineur	Important	Important	Majeur
Majeur	Important	Majeur	Majeur	Critique
Critique	Important	Majeur	Critique	Critique

Usage dans le cas des tests d'intrusion

Les tests d'intrusion peuvent recourir à l'outil CVSS 3.1 (https://www.first.org/cvss/v3.1/) pour estimer le niveau de risque associé aux vulnérabilités découverte. Dans ce cas, les trois métriques sont utilissées :

L'outil CVSS est composé de trois groupes de métriques : base, temporelle et environnementale. Le score de base reflète la gravité d'une vulnérabilité en fonction de ses caractéristiques intrinsèques qui sont constantes dans le temps et suppose le pire impact raisonnable dans les différents environnements déployés.

Les mesures temporelles ajustent la gravité de base d'une vulnérabilité en fonction de facteurs qui changent au fil du temps, tels que la disponibilité du code d'exploitation. Les mesures environnementales ajustent les sévérités de base et temporelles à l'environnement audité. Ils prennent en compte des facteurs tels que la présence de mesures d'atténuation dans cet environnement.

Score CVSS	Risque
9,0 à 10,0	Critique
7,0 à 8,9	Majeur
4,0 à 6,9	Important
0,1 à 3,9	Mineur

Niveau de risque

L'évaluation des risques repose sur la matrice de calcul du risque donnée ci-dessus. Elle est complétée avec les score CVSS 3.1 (tests d'intrusion) et est rappelée ci-dessous :

Risque		Score CVSS
Critique	Risque critique sur le système d'information et nécessitant une correction immédiate ou imposant un arrêt immédiat du service.	9,0 à 10,0
Majeur	Risque majeur sur le système d'information nécessitant une correction à court terme.	7,0 à 8,9
Important	Risque modéré sur le système d'information et nécessitant une correction à moyen terme.	4,0 à 6,9
Mineur	Faible risque sur le système d'information et pouvant nécessiter une correction.	0,1 à 3,9

Métriques des recommandations
Chaque mesure est accompagnée d'une estimation de la complexité de mise en œuvre et d'une priorisation.
Complexité de mise en œuvre

Complexité	
Complexe	Des compétences spécifiques sont nécessaires pour la mise en œuvre, un investissement important est à prévoir en termes de ressource, de temps ou d'argents.
Élevée	Des compétences spécifiques sont nécessaires pour la mise en œuvre, la mise en œuvre peut être coûteuse en temps et ressources. Peut nécessiter la collaboration de plusieurs services
Modérée	Peut nécessiter des compétences standards ou la collaboration de plusieurs personnes ou services.
Facile	Ne nécessite pas de compétence particulière et peut être mis en œuvre sans déployer de moyens conséquents

Priorité

Priorité	
Urgent	La mise en œuvre de la mesure est jugée prioritaire et des ressources devrait y être consacrées au plus vite. La mesure doit permettre de corriger une vulnérabilité majeure ou critique
Court terme	La mise en œuvre de la mesure devrait être effectuée dans le mois. La mesure doit permettre de corriger un risque juger important.
Moyen terme	Cette mesure n'est pas particulièrement critique ou peut nécessiter du temps pour la transformation. Une planification dans le semestre est à prévoir

Long terme	Cette mesure n’est pas prioritaire ou doit s’étudier dans le temps long. La mesure pourrait être envisagée dans le cadre d’un plan triennal de mise en place de la sécurité.

Les recommandations du niveau renforcée du guide d’hygiène de l’ANSSI ont été jugées comme pouvant être étudiées au long terme.

Métriques de conclusion de l'audit

Niveau de conformité globale

L'évaluation du **niveau de conformité globale** repose sur l'échelle de valorisation proposée ci-dessous :

Conclusion	Description
Très satisfaisant	Le système d'information démontre un niveau de conformité supérieur à 90% aux critères d'audits et aucune non-conformité importante n'a été identifiée
Satisfaisant	Le système d'information démontre un niveau de conformité supérieur à 90% à l'arrêté sectoriel et aucune non-conformité majeure n'a été identifiée
Perfectible	Le système d'information démontre un niveau de conformité inférieur à 90% à l'arrêté sectoriel et aucune non-conformité majeure n'a été identifiée
Insuffisant	Le système d'information démontre un niveau de conformité inférieur à 50% à l'arrêté sectoriel ou des non-conformités majeures ont été identifiées
Très insuffisant	Le système d'information démontre un niveau de conformité inférieur à 50% à l'arrêté sectoriel et des risques critiques et immédiats ont été identifiés

Le niveau à atteindre, définissant les axes de la politique de sécurité, est proposé en prenant en compte les exigences de sécurité et le niveau de maturité actuel.

Niveau de sécurité global

L'évaluation du **niveau de sécurité global** repose sur l'échelle de valorisation proposée ci-dessous :

Conclusion	Description
Très satisfaisant	La cible de l'audit répond parfaitement à l'état l'art de la sécurité face à de l'intrusion en termes réseau, système et applicatif.
Satisfaisant	La cible de l'audit répond à l'état de l'art de la sécurité face à de l'intrusion. Cependant, quelques améliorations permettront d'améliorer encore d'avantage votre niveau général.
Moyen	La cible de l'audit ne répond que partiellement à l'état de l'art de la sécurité face à de l'intrusion. Des corrections notables sont à prévoir pour améliorer le niveau de sécurité général de votre SI.
Faible	La cible de l'audit est exposée à des attaques dont les conséquences peuvent être non négligeables. Des corrections doivent être apportées à court terme afin de supprimer les vulnérabilités détectées.
Très faible	La cible de l'audit ne dispose d'aucune mesure de sécurité suffisante pour bloquer certaines attaques ayant pour conséquence la compromission partielle ou totale de votre SI. Des corrections doivent être apportées dans les plus brefs délais.

De : MICHEL Erwan <erwan.michel@soprasteria.com>
Envoyé : vendredi 20 février 2026 11:00
À : erwan.michel@oxilum.fr
Objet : Test

Mon adresse

C2 – Usage restreint